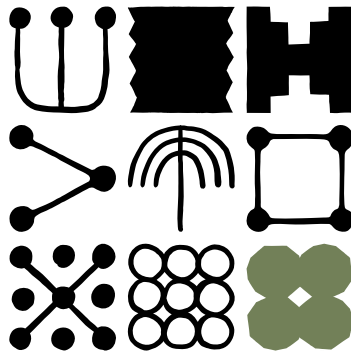


超越权限提示：让 Claude Code 更安全、更自主

Beyond permission prompts: making Claude Code more secure and autonomous

Anthropic · 2025-10-20 · 原文 / Source

完整译文与英文逐段对照。依据你提供的网页存档翻译，保留原文的观点、例子与限定条件。图表（含图注）、代码及其中的文字维持原文；网页导航、订阅表单和站点页脚不属于文章正文。中文为学习用非官方译文。



Claude Code 新增了两项沙箱功能：沙箱化的 bash 工具与网页版 Claude Code。它们通过文件系统隔离和网络隔离两道边界，减少权限提示，并提升用户安全性。

在 Claude Code 中，Claude 与你一起编写、测试和调试代码，浏览代码库、编辑多个文件，并运行命令验证自己的工作。向 Claude 开放如此广泛的代码库和文件访问权限，可能带来风险，尤其是在遭遇提示词注入时。

为帮助解决这个问题，我们在 Claude Code 中引入了两项基于沙箱的新功能。它们都旨在为开发者提供更安全的工作环境，同时让 Claude 能够更自主地运行，减少权限提示。在内部使用中，我们发现，沙箱能够在保障安全的同时，将权限提示减少 84%。通过划定明确边界，让 Claude 在边界内自由工作，这些功能同时提升了安全性与自主行动能力。

保障 Claude Code 用户的安全

Claude Code 采用基于权限的运行模式：默认情况下处于只读状态，这意味着在修改内容或运行命令之前，它都会请求许可。不过也有一些例外：对于 echo 或 cat 这样的安全命令，我们会自动允许执行，但大多数操作仍需明确批准。

不断点击“批准”会拖慢开发周期，还可能造成“审批疲劳”：用户可能不再仔细留意自己批准了什么，反而降低了开发过程的安全性。

为此，我们为 Claude Code 推出了沙箱机制。

沙箱：更安全、更自主的方式

沙箱预先划定边界，让 Claude 在边界内更自由地工作，而无需为每一个动作请求许可。启用沙箱后，权限提示会大幅减少，安全性也会提升。

我们的沙箱方案建立在操作系统级功能之上，形成两道边界：

1. **文件系统隔离**，确保 Claude 只能访问或修改特定目录。这对防止遭受提示词注入的 Claude 修改敏感系统文件尤为重要。
2. **网络隔离**，确保 Claude 只能连接已获批准的服务器。这能防止遭受提示词注入的 Claude 泄露敏感信息或下载恶意软件。

有效的沙箱需要同时具备文件系统隔离与网络隔离。如果没有网络隔离，被攻陷的 Agent 可能会将 SSH 密钥等敏感文件外传；如果没有文件系统隔离，被攻陷的 Agent 则可能轻易逃出沙箱并获得网络访问能力。正是通过同时使用这两种技术，我们才能为 Claude Code 用户提供更安全、更快速的 Agent 使用体验。

Claude Code 的两项沙箱新功能

沙箱化的 bash 工具：无需权限提示，也能安全执行 bash

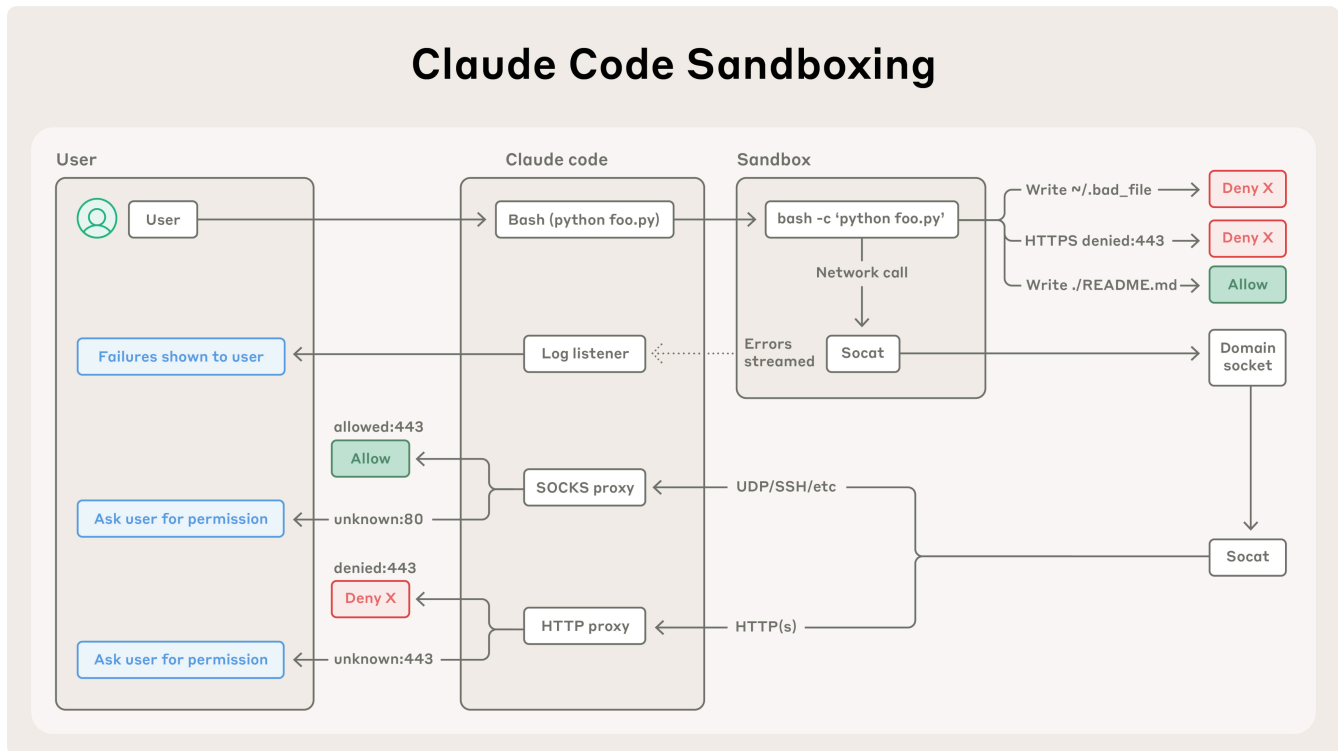
我们推出了一个新的沙箱运行时，目前以 beta 研究预览版提供。它让你能够精确定义 Agent 可以访问哪些目录和网络主机，而不必承担启动和管理容器的开销。它可以用于隔离任意进程、Agent 和 MCP 服务器，并且也以开源研究预览版的形式提供。

在 Claude Code 中，我们使用这个运行时对 bash 工具进行沙箱隔离，让 Claude 在你设定的范围内运行命令。在安全的沙箱内部，Claude 可以更自主地运行，安全执行命令而无需权限提示。如果 Claude 尝试访问沙箱之外的内容，你会立即收到通知，并可以决定是否允许。

我们基于 Linux bubblewrap 和 macOS seatbelt 等操作系统级原语构建了这一机制，在操作系统层面强制执行限制。这些限制不仅覆盖 Claude Code 的直接交互，也覆盖命令所启动的所有脚本、程序和子进程。如上所述，这个沙箱同时强制执行：

1. **文件系统隔离**：允许读写当前工作目录，但阻止修改该目录之外的任何文件。
2. **网络隔离**：只允许通过 Unix 域套接字访问互联网，该套接字连接到运行于沙箱外部的代理服务器。代理服务器限制进程可以连接的域名，并在请求新域名时处理用户确认。如果你希望进一步增强安全性，还可以自定义这个代理，对出站流量施加任意规则。

这两个组件都可以配置：你可以方便地允许或禁止特定文件路径或域名。



Claude Code's sandboxing architecture isolates code execution with filesystem and network controls, automatically allowing safe operations, blocking malicious ones, and asking permission only when needed.

沙箱确保即使提示词注入成功，其影响也会被完全隔离，无法危及用户的整体安全。这样，即便 Claude Code 被攻陷，也无法窃取你的 SSH 密钥，或向攻击者的服务器回传信息。

要开始使用此功能，请在 Claude Code 中运行 `/sandbox`，并查看有关我们安全模型的更多技术细节。

为了让其他团队更容易构建安全的 Agent，我们已经开源了这项功能。我们认为，其他团队应考虑在自己的 Agent 中采用这项技术，以增强其安全防护能力。

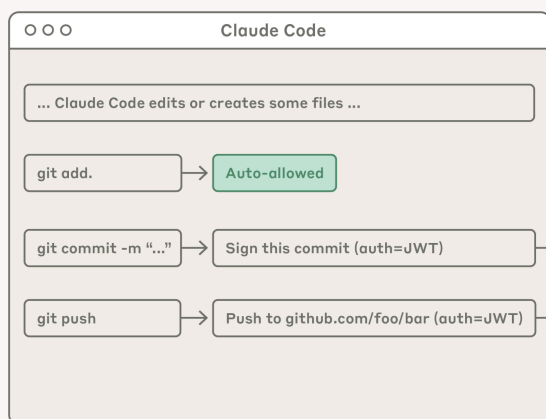
网页版 Claude Code：在云端安全运行 Claude Code

今天，我们还发布了网页版 Claude Code，让用户可以在云端的隔离沙箱中运行 Claude Code。网页版 Claude Code 将每个会话放在独立的沙箱中执行，在保障安全的前提下，让它完整访问所在服务器。我们设计这个沙箱时，确保敏感凭据，例如 git 凭据或签名密钥，绝不会与 Claude Code 一起存在于沙箱内部。这样，即使沙箱中运行的代码被攻陷，也能保护用户免受进一步损害。

网页版 Claude Code 使用一个定制代理服务，透明地处理所有 git 交互。在沙箱内部，git 客户端使用专门构建、限定权限范围的凭据向该服务认证。代理会验证凭据和 git 交互的内容，例如确保只向已配置的分支推送，然后附上正确的身份验证令牌，再将请求发送给 GitHub。

Claude.com/code

GVisor Sandbox



Git proxy

- 1. Validate JWT auth
- 2. Validate pushed branch name
- 3. Validate pushed repo destination

Github.com



Claude Code's Git integration routes commands through a secure proxy that validates authentication tokens, branch names, and repository destinations—allowing safe version control workflows while preventing unauthorized pushes.

开始使用

对于使用 Claude 开展工程工作的开发者，新的沙箱化 bash 工具和网页版 Claude Code，在安全性与生产力方面都带来了显著改善。

要开始使用这些工具：

1. 在 Claude 中运行 `/sandbox`，并查阅文档，了解如何配置沙箱。
2. 前往 claude.com/code，体验网页版 Claude Code。

如果你正在构建自己的 Agent，也可以查看我们的开源沙箱代码，考虑将其集成到你的项目中。我们期待看到你的成果。

若想进一步了解网页版 Claude Code，请阅读我们的发布博客文章。

致谢

本文由 David Dworken 和 Oliver Weller-Davies 撰写，Meaghan Choi、Catherine Wu、Molly Vorwerck、Alex Isken、Kier Bradwell 和 Kevin Garcia 参与贡献。